Sécurité des systèmes informatiques

Certificats numériques et protocoles sécurisés

Abdeltouab Belbekkouche

a.belbekkouche@umontreal.ca

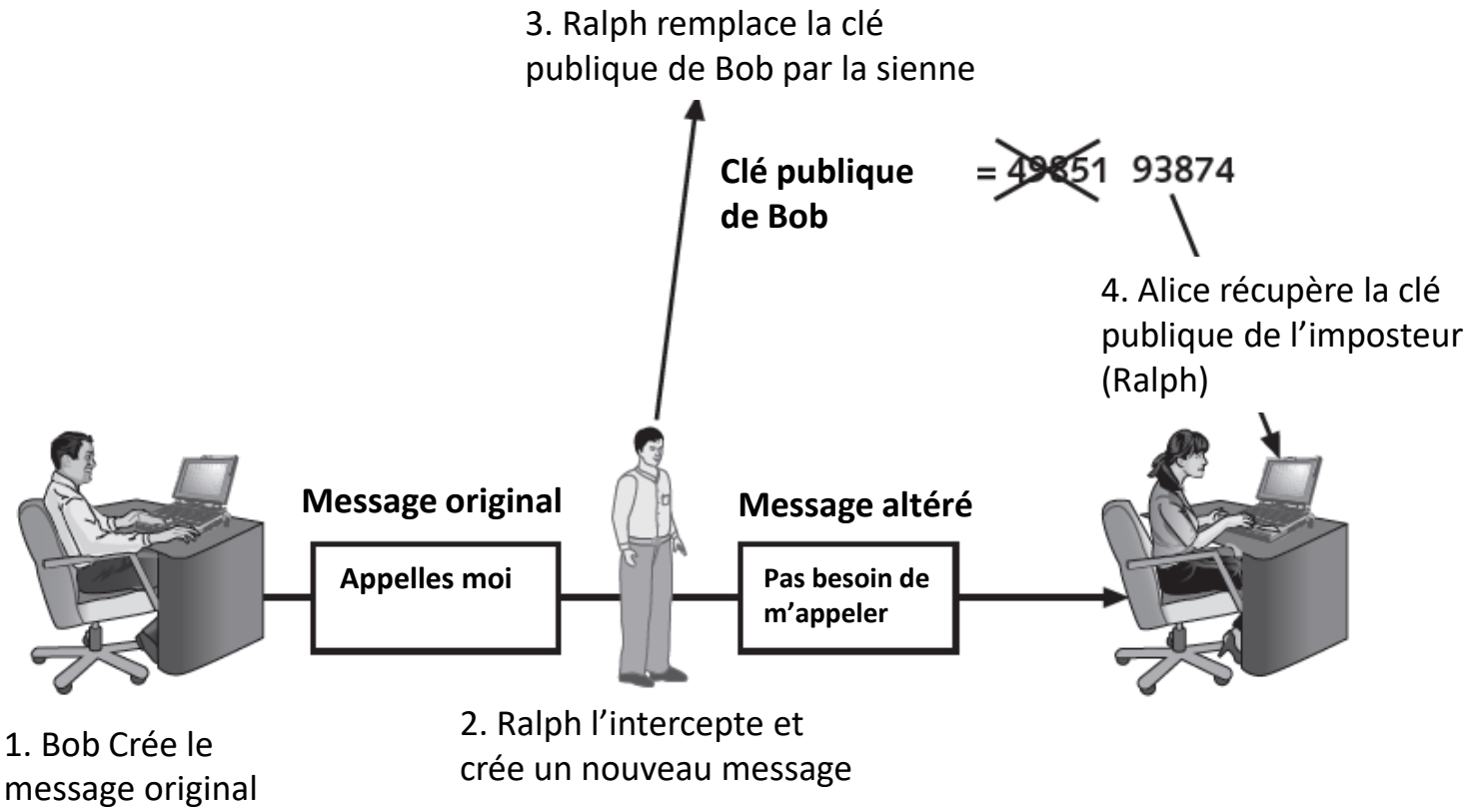
Université de Montréal

Contenu

- Certificats numériques
- Infrastructure à clé publique
- Protocoles sécurisés

Certificat numérique

- Signature numérique
  - Prouver l'origine d'un document
  - **Inconvénient:** un imposteur peut publier une fausse clé publique d'un autre utilisateur



Certificat numérique (suite)

- Solution: **Tiers de confiance**
  - Aider à résoudre le problème de vérification d'identité
  - Vérifier le propriétaire et que la clé publique lui appartient
  - Aider à prévenir les attaques de type **homme-au-milieu** (*man-in-the-middle*)qui imitent le propriétaire d'une clé publique
- Informations contenues dans un certificat
  - Nom ou alias du propriétaire
  - Clé publique du propriétaire
  - Nom de l'émetteur du certificat
  - Signature numérique du propriétaire
  - Numéro de série du certificat
  - Date d'expiration de la clé publique
  - …

Gestion des certificats numérique

- Entités et technologies impliquées
  - Autorité de Certification (***C****ertificate* ***A****uthority*, CA)
  - Autorité d'Enregistrement (***R****egistration* ***A****uthority,* RA)
  - Liste de Révocation de Certificats (***C****ertificate* ***R****evocation* ***L****ist*, CRL)
  - Dépôt de Certificats (***C****ertificate* ***R****epository*, CR)
  - Navigateur Web

Gestion des certificats numérique (suite)

- Autorité de Certification (CA)
  - Délivrance des certificats numériques
  - Interne ou externe à l'organisation

Fonctions
Générer et délivrer des certificats de clés publiques
Délivrer des certificats pour d'autres CA
Générer et publier des informations sur l'état des certificats
Inscrire des demandes de révocation
Révoquer des certificats de clés publiques
Maintenir la sécurité, la disponibilité et la continuité du service de signature de certificats

Un abonné qui demande un certificat numérique
Génère sa clé publique et sa clé privée
Envoie sa clé publique à la CA (la CA peut dans certains cas générer les deux clés)
La CA insère la clé publique dans un certificat
La CA signe le certificat avec sa clé privée

Gestion des certificats numérique (suite)

- Autorité d'Enregistrement (RA)
  - Entité subordonnée à une CA qui réalise une partie de ses fonctions
    - Recevoir, authentifier et traiter les demandes de révocation
    - Identifier et authentifier les abonnées
    - Obtenir la clé publique de l'abonné
    - Vérifier l'identité d'un individu
      - Email
      - Documents (certificat de naissance, badge employé, etc.)
      - En personne (permis de conduire, passeport, etc.)
    - Initier le processus de certification avec la CA

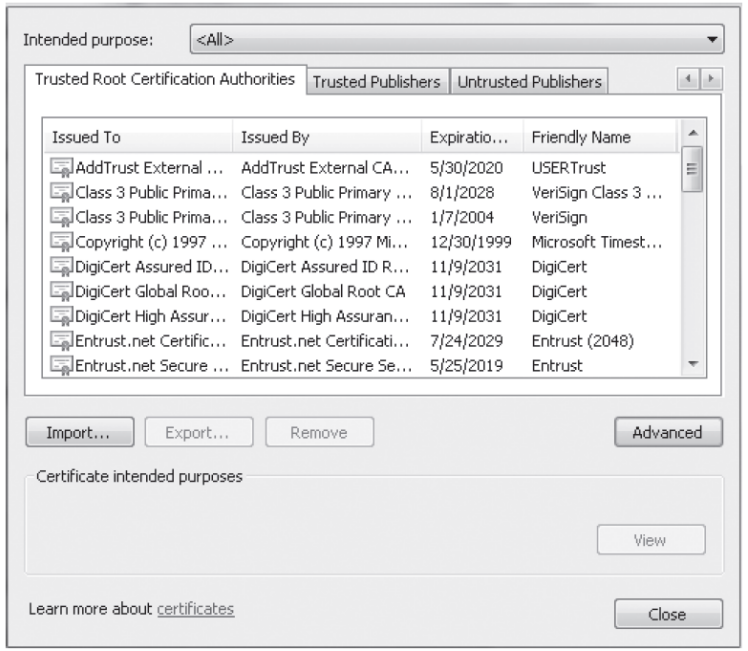
Gestion des certificats numérique (suite)

- **Liste de Révocation de Certificats (CRL)**
  - Le certificat n'est plus utilisé
  - Les détails du certificat ont changé
    - Exemple: l'adresse du propriétaire a changé
  - La clé privée a été perdue ou exposée (ou suspectée de l'être)

- **Dépôt de Certificats (CR)**
  - Annuaire centralisé des certificats numériques accessible au public
  - Consulter l'état des certificats
  - Peut être crée et géré localement comme une zone de stockage connecté au serveur CA

Gestion des certificats numérique (suite)

- **Gestion du navigateur Web**
  - Les navigateurs Web modernes sont préconfigurés avec des listes de CA par défaut
  - Avantages
    - Les utilisateurs peuvent profiter des certificats numériques sans faire recours au téléchargement manuel des informations
    - Les utilisateurs n'ont pas à télécharger les listes de révocation manuellement (mises à jour automatiques)

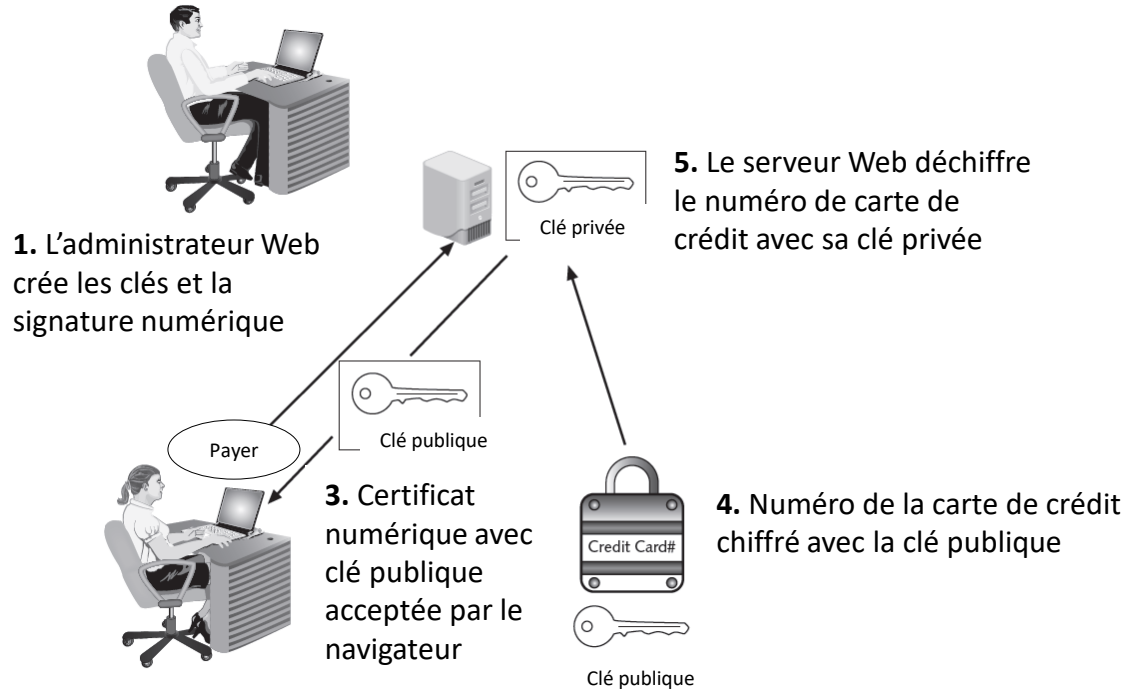


Types de certificats numériques

- **Classe 1**: certificats personnelles
  - Délivrés par une RA
  - Souvent utilisés pour sécuriser la transmission de courriels
  - Nécessite le nom du propriétaire et son adresse courriel

Types de certificats numériques

- **Classe 2**: certificats de serveurs
  - Envoyés au clients par un serveur Web
  - **1)** Assure l'authenticité du serveur Web
  - **2)** Assure la confidentialité de la connexion avec le serveur Web
  - **1)** et **2)** peuvent être combinés en un seul certificat



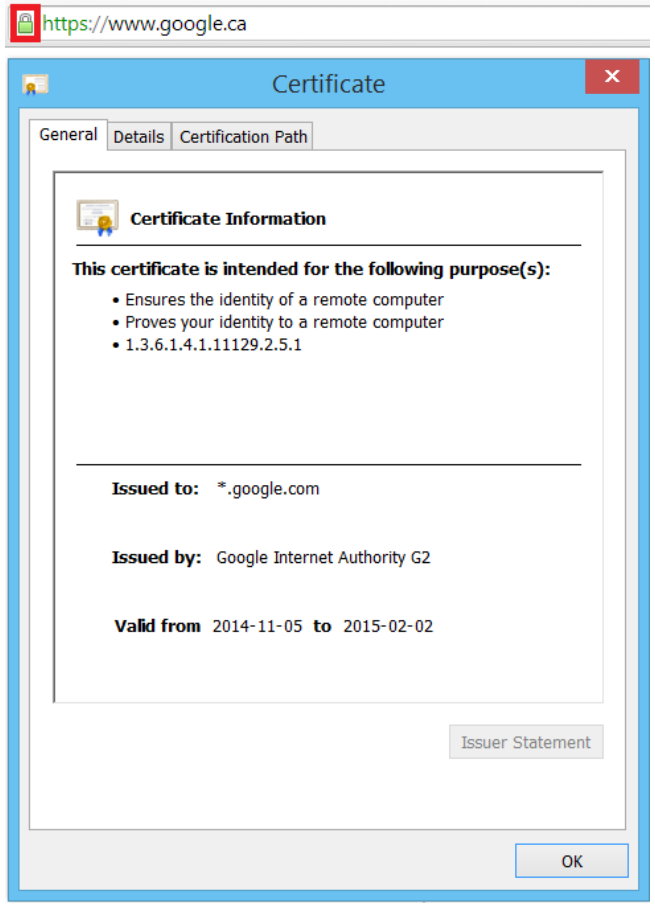
1. L'administrateur Web crée les clés et la signature numérique

2. L'utilisateur clique sur « Payer maintenant »

3. Certificat numérique avec clé publique acceptée par le navigateur

4. Numéro de la carte de crédit chiffré avec la clé publique

5. Le serveur Web déchiffre le numéro de carte de crédit avec sa clé privée



Types de certificats numériques (suite)

- Certificat SSL à validation étendue (*Extended Validation SSL*, EV SSL)
  - Nécessite une vérification plus approfondie de la légitimité de l'entreprise
- **Classe 3:** certificats numériques des éditeurs de logiciels (*software publisher digital certificates*)
  - Fournit par les éditeurs de logiciels
  - But: vérifier la sécurité des logiciels
- **Classe 4:** transactions commerciales en ligne entre compagnies
- **Classe 5:** sécurité des organisations privées ou gouvernementales
- Certificats à double clé (*Dual-key*)
  - Authentification (signature numérique) et confidentialité
- Certificats à double sens (*Dual-sided*)
  - Serveur et client

Types de certificats numériques (suite)

- Certificats numérique X.509
  - Standard le plus utilisé pour déterminer le format des certificats numériques

Certificat
Version du certificat
Numéro de série
Algorithme utilisé pour signer le certificat
Nom de l'organisme qui a généré le certificat *Le couple numéro de série – nom de l'organisme doit être unique*
Période de validité
Nom du propriétaire du certificat
Clé publique du propriétaire
Informations additionnelles concernant le propriétaire ou les mécanismes de chiffrement
Signature du certificat *Algorithme et paramètres utilisés pour la signature et signature à proprement parlé*

Infrastructure à clé publique

- *Public Key Infrastructure* (**PKI**)
- Cadre (*framework*) pour toutes les entités impliquées dans la gestion des certificats numériques
- Outil important pour la gestion des certificats numériques et la cryptographie asymétrique
- Actions facilitées par la PKI: **créer**, **stocker**, **distribuer** et **révoquer** les certificats numériques
- Aspects de la PKI
  1. Standards de cryptographie à clé publique
  2. Modèle de confiance
  3. Gestion des clés

Standards de cryptographie à clé publique

- *Public-Key Cryptographic Standards* (**PKCS**)
- Ensemble numéroté de standards PKI définis par la compagnie RSA
  - Largement accepté dans l'industrie
  - Basé sur l'algorithme cryptographique à clé publique RSA

PKCS #	Version actuelle	Nom	Description
PKCS #1	2.1	RSA Cryptography Standard	Définit le chiffrement et le format de la signature numérique en utilisant l'algorithme RSA
PKCS #2	S/O	S/O	Originalement, définit le chiffrement du message résumé (fait partie de PKCS #1 maintenant)
PKCS #3	1.4	Diffie-Hellman Key Agreement Standard	Échange de clés secrètes en utilisant l'algorithme Diffie-Hellman
PKCS #4	S/O	S/O	Originalement, définit la syntaxe des clés RSA (fait partie de PKCS #1 maintenant)
PKCS#5	2.0	Password-Based Cryptography Standard	Décrit la méthode de génération d'une clé secrète à partir d'un mot de passe (PBE)
PKCS #6	1.5	Extended-Certificate Syntax Standard	Décrit la syntaxe d'un certificat étendu (retiré graduellement)

Standards de cryptographie à clé publique (suite)

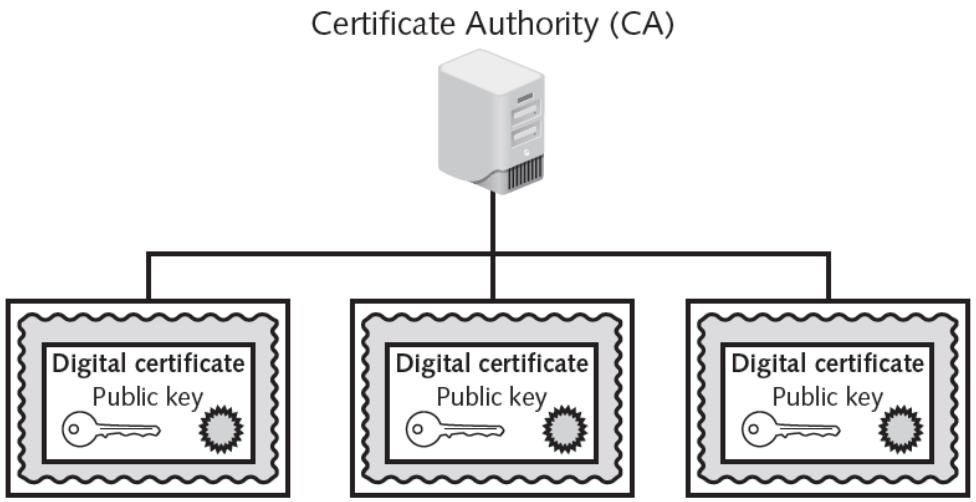
PKCS #	Version actuelle	Nom	Description
PKCS #7	1.5	Cryptographic Message Syntax Standard	Définit une syntaxe générique pour la signature numérique
PKCS #8	1.2	Private-Key Information Syntax Standard	Définit la syntaxe et les attributs des clés privés. Aussi définit une méthode pour trier les clés
PKCS #9	2.0	Selected Attribute Types	Définit les type d'attributs utilisés dans les formats de données définis dans PKCS #6, PKCS #7, PKCS #8, and PKCS #10
PKCS #10	1.7	Certification Request Syntax Standard	Décrit la syntaxe d'une requête envoyée à un CA pour demander un certificat numérique
PKCS #11	S/O	Cryptographic Token Interface Standard	...
PKCS #12	1.0	Personal Information Exchange Syntax Standard	...
PKCS #13	En développement	Elliptic Curve Cryptography Standard	...
PKCS #14	En développement	PRNG Standard	...
PKCS #15		Cryptographic Token Information Format	...

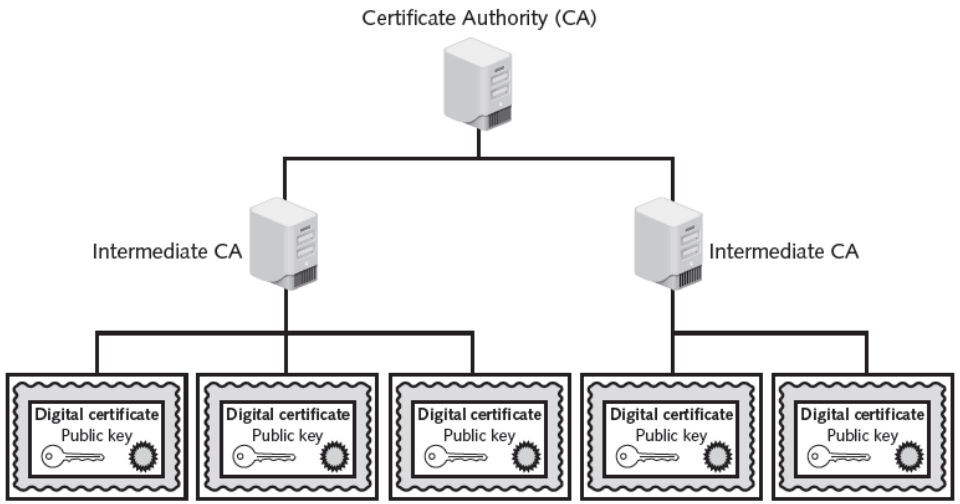
Modèles de confiance

- *Trust models*
- Le type de relations de confiance qui peut exister entre individus et entités
  - **Directe**
    - Une personne connait l'autre
  - **Tiers de confiance**
    - Deux personnes se font confiance car les deux font confiance à une troisième personne

Modèles de confiance (suite)

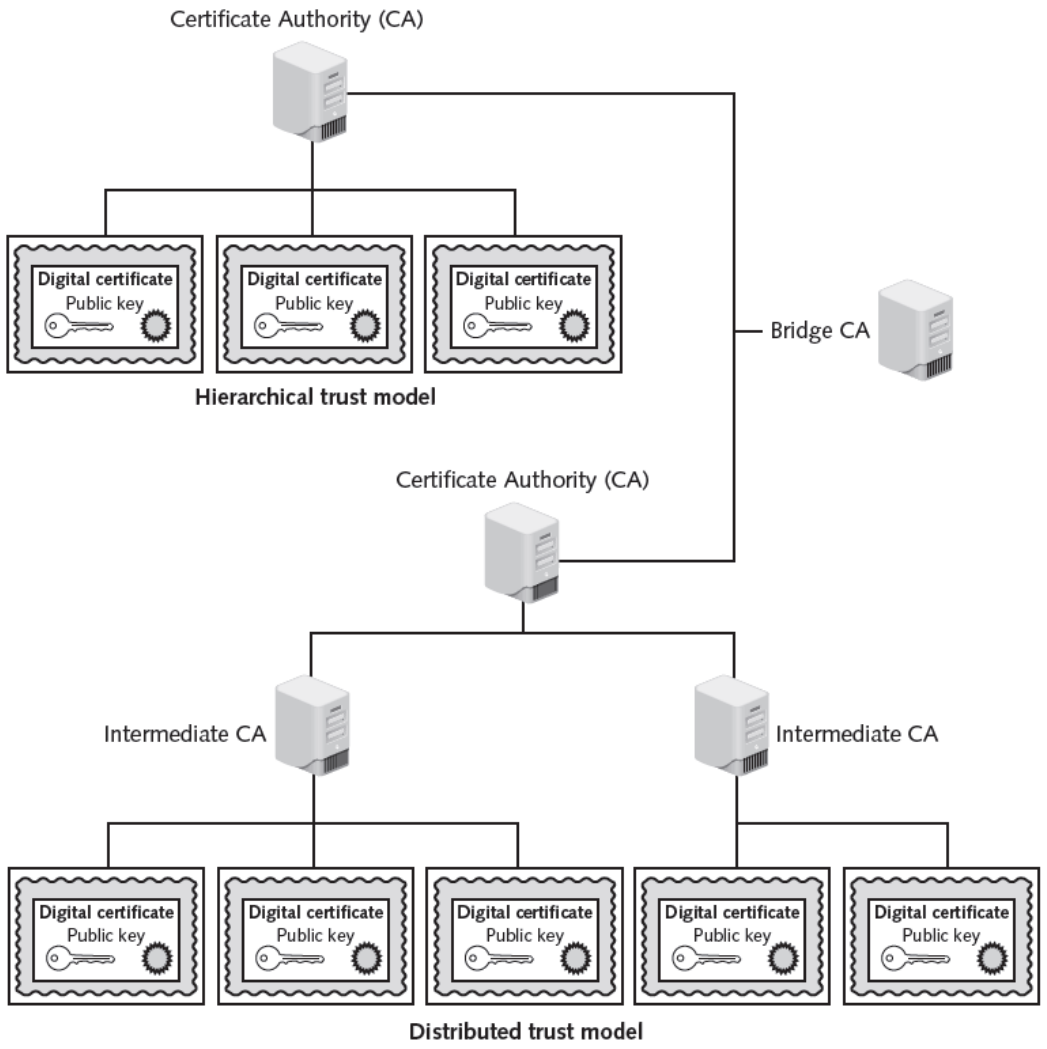
- **Modèle hiérarchique**
  - Une seule hiérarchie avec une CA à la racine (*Root*)
  - La CA racine signe tous les certificats avec la même clé
  - Approprié au sein d'une même organisation
  - Inconvénients
    - Charge de travail pour la CA racine
    - Compétition entre CAs
    - Et si la clé privée de la racine est compromise!
- **Modèle distribué**
  - Plusieurs CAs peuvent signer les certificats
  - Élimine les limitations du modèle hiérarchique





Modèles de confiance (suite)

- Passerelle (*Bridge*)
  - Une CA facilite la connexion entre toutes les autres CAs
  - La CA facilitatrice ne délivre pas de certificats
  - Permet la liaison entre différents modèles de confiance
  - Exemple de passerelles
    - Gouvernements fédéral et gouvernements provinciaux
    - Industrie pharmaceutique
    - Industrie Aérospatiale
    - Etc.



Gestion d'une PKI

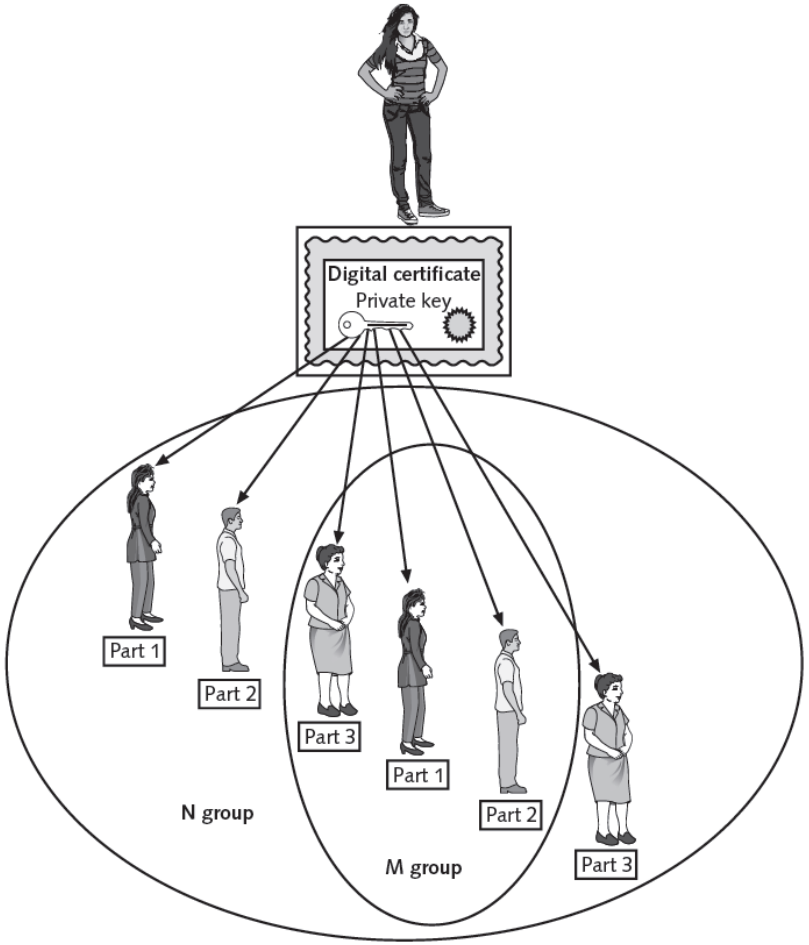
- Politique de certification (*Certificate Policy*, CP)
  - Détermine les règles qui gouvernent le fonctionnement d'une PKI
  - Fournit les recommandations en termes de besoins de sécurité pour la CA, les RA et les autres entités
- Déclaration des pratiques de certification (*Certificate Practice Statement*, CPS)
  - Décrit en détail comment la CA doit utiliser et gérer les certificats
- Cycle de vie d'un certificat
  - Création
    - Après l'identification positive de l'utilisateur
  - Suspension
    - Exemple: absence prolongée d'un employé
  - Révocation
    - Exemple: compromission de la clé privée
  - Expiration

Gestion des clés

- Stockage de la clé publique
  - Intégration dans un certificat numérique
- Stockage de la clé privée
  - Sur le système local du propriétaire
  - Logiciel ou matériel
- Plusieurs paires de clés
  - Si les besoins de sécurité les requièrent
    - Une paire de clés pour le chiffrement de l'information
    - Une paire pour la signature numérique
- Autorité de séquestre (*Key Escrow*)
  - Les clés sont gérés par une tiers partie
  - Diviser la clé en deux, chiffrer chaque partie et la stocker dans un endroit différent

Gestion des clés (suite)

- Expiration
  - Les clés expirent après une période de temps prédéfinie
- Renouvellement
  - Les clés existantes peuvent être renouvelées
- Révocation
  - Les clés peuvent être révoquées avant leur date d'expiration
  - Les clés révoquées ne peuvent être restaurées
- Récupération
  - Exemple: besoin de récupérer la clé d'un employé hospitalisé pour une période prolongée
  - Utilisation d'un agent de récupération (personne de confiance)
  - Utiliser un groupe de personnes (contrôle M-de-N)



Protocoles sécurisés

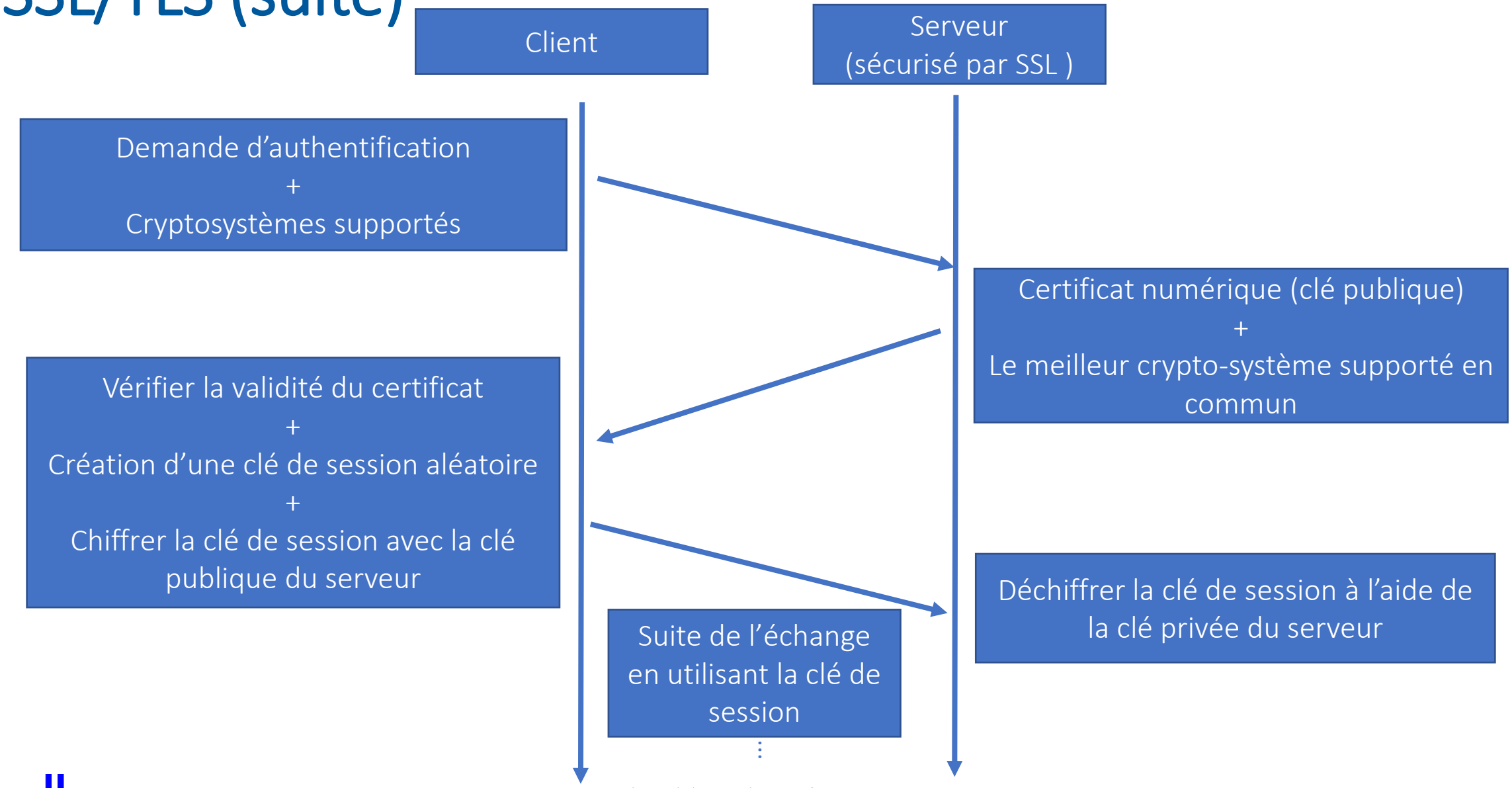
- SSL/TLS
- SSH
- S-HTTP
- SET
- DNSsec

SSL/TLS

- SSL (*Secured Socket Layer* ou couche de sockets sécurisée)
- Procédé de sécurisation des transactions effectuées sur Internet: établir un canal sécurisé de communication (chiffré) entre deux machines: un client et un serveur
- Repose sur la cryptographie asymétrique (à clé publique)
- Transparent à l'utilisateur
  - Indépendant du protocole utilisé (HTTP, FTP, POP, IMAP, etc.)
  - Couche supplémentaire assurant la sécurité entre la couche application et la couche transport
- 2001
  - Brevet de SSL racheté par l'IETF (*Internet Engineering Task Force*)
  - Rebaptisé **TLS** (*Transport Layer Security*)

SSL/TLS (suite)

Principe de fonctionnement (SSL 2.0)



SSH

- SSH (*Secure Shell*) permet à des utilisateurs (ou services TCP/IP) d'accéder à une machine à travers une canal chiffré (*tunnel*)
- Ouvrir une session interactive sur un serveur pour envoyer des commandes ou des fichiers
- Alternative à *telnet*, *rsh*, *rlogin* et *rexec*
- Principe de fonctionnement
  - Le client et le serveur s'authentifient mutuellement
    - Le serveur envoie sa clé publique
    - Le client génère une clé de session de 256 bits, la chiffre avec la clé publique du serveur et l'envoie à ce dernier
  - Les données circulant entre le client et le serveur sont chiffrées
    - En utilisant clé se session

S-HTTP

- *Secure HTTP* (Protocole HTTP sécurisé)
- Une amélioration du protocole HTTP pour offrir la sécurisation des échanges lors de transactions de commerce électronique
- Chiffrer directement les messages HTTP (couche applicative)
- S-HTTP et SSL sont complémentaires

SET

- SET (*Secure Electronic Transaction*)
- Protocole de sécurisation des transactions électroniques qui s'appui sur SSL
- Utilisation d'une signature numérique de l'acheteur
- Une transaction mettant en jeu non seulement le client et le marchand, mais aussi leurs banques respectives
  - Le marchand n'a pas accès aux informations bancaires sensibles du client

DNSsec

- DNSsec (*Domain Name System Security Extensions*)
- Les serveurs DNS sont des ordinateurs qui structurent le Web mondial
- DNSsec: une extension du protocole DNS
- Buts
  - Assurer l'authentification et l'intégrité des enregistrements DNS
  - Contrer les failles du protocole DNS et le **DNS *poisoning***
- Principe de fonctionnement
  - Vérification des signatures numériques et échange de données chiffrées